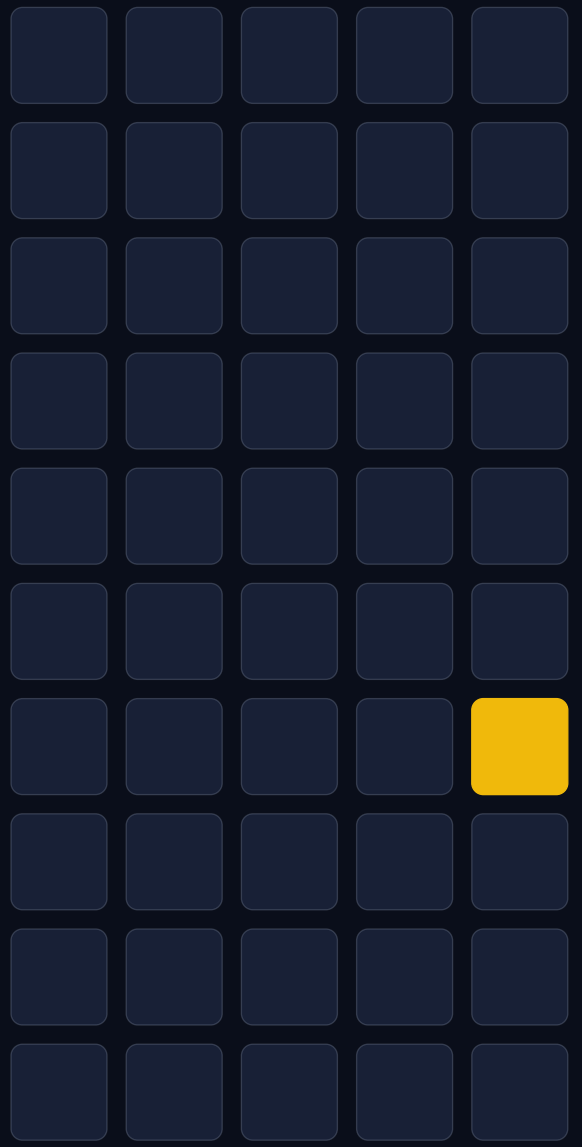
BINANCE · 29 OTTOBRE 2026

Anatomia dell'hack da 6,3 miliardi

Cosa è successo, come è stato possibile e cosa insegna. In versione tecnica e in parole semplici.

Teodoro Corbo · Aggiornato al 2 novembre 2026 · indagine ancora in corso



50 firme preparate. Una sola valida.

VERIFICATO ON-CHAIN

DICHIARATO DA BINANCE

L'attacco in 60 secondi

6,3

miliardi di $ rubati in una sera

15

minuti per portarne via 4,9 mld

10–11

blockchain colpite in parallelo

50:1

firme preparate contro firme usate

2,8

miliardi di $ congelati dagli emittenti



Nessuna chiave privata rubata, secondo Binance. L'attaccante è riuscito a far firmare ai sistemi di Binance i propri prelievi. Su Ethereum ha usato EIP-7702 per trasformare un hot wallet in un «aspiratore» che obbediva solo a lui.

Fonti: Binance, TRM Labs, Elliptic, Arkham, Blockaid. 4,9 mld nei primi ~15 minuti: Arkham. 10 chain per TRM, 11 per Elliptic.

GUIDA ALLA LETTURA

Come leggere questo deck

VERIFICATO ON-CHAIN

Confermato sulla blockchain da almeno due fonti indipendenti e autorevoli.

DICHIARATO DA BINANCE

Affermazioni ufficiali di Binance. Utili per la cronologia, ma Binance è la parte in causa.

IPOTESI DEGLI ANALISTI

Deduzioni di società e ricercatori. Plausibili, da rivedere quando uscirà il post-mortem.

Slide scure
La parte tecnica: dati on-chain, meccanismi, indirizzi.

Slide chiare · IN PAROLE SEMPLICI
La stessa cosa spiegata senza gergo, con un'analogia.

Fonti di riferimento: TRM Labs · Elliptic · Chainalysis · Arkham · Binance · Blockaid. Elenco completo in appendice.

01

Cosa è successo

Le basi, i numeri e la cronologia minuto per minuto



IN PAROLE SEMPLICI

Hot wallet, cold wallet e firme



Cold wallet = il caveau

Offline, custodisce la maggior parte dei fondi. Lento da aprire, difficile da attaccare.



Hot wallet = la cassa del negozio

Online, serve ai prelievi di ogni giorno. Sempre pronto, quindi più esposto.



La firma è il timbro

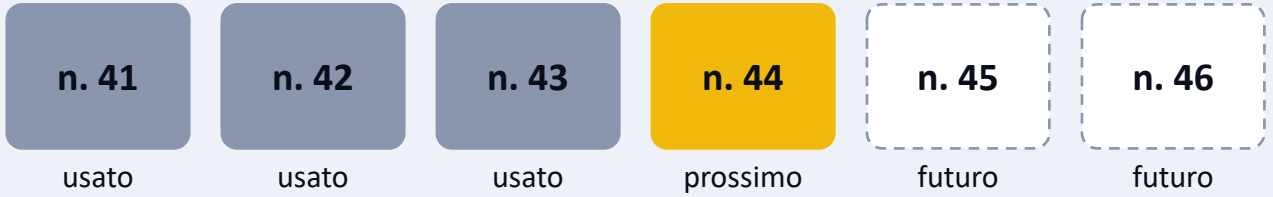
Ogni movimento di fondi deve portare una firma digitale valida. La blockchain non chiede chi sei: controlla solo il timbro.

Chi controlla il sistema che appone i timbri controlla i soldi. È il punto colpito a Binance.

APPROFONDIMENTO

Il nonce: il numero progressivo di ogni wallet

Il contatore di un wallet Ethereum



- **Firma per il n. 42** → rifiutata: numero già usato
- **Firma per il n. 44** → accettata: è il prossimo numero
- **Firma per il n. 46** → in attesa: mancano il 44 e il 45

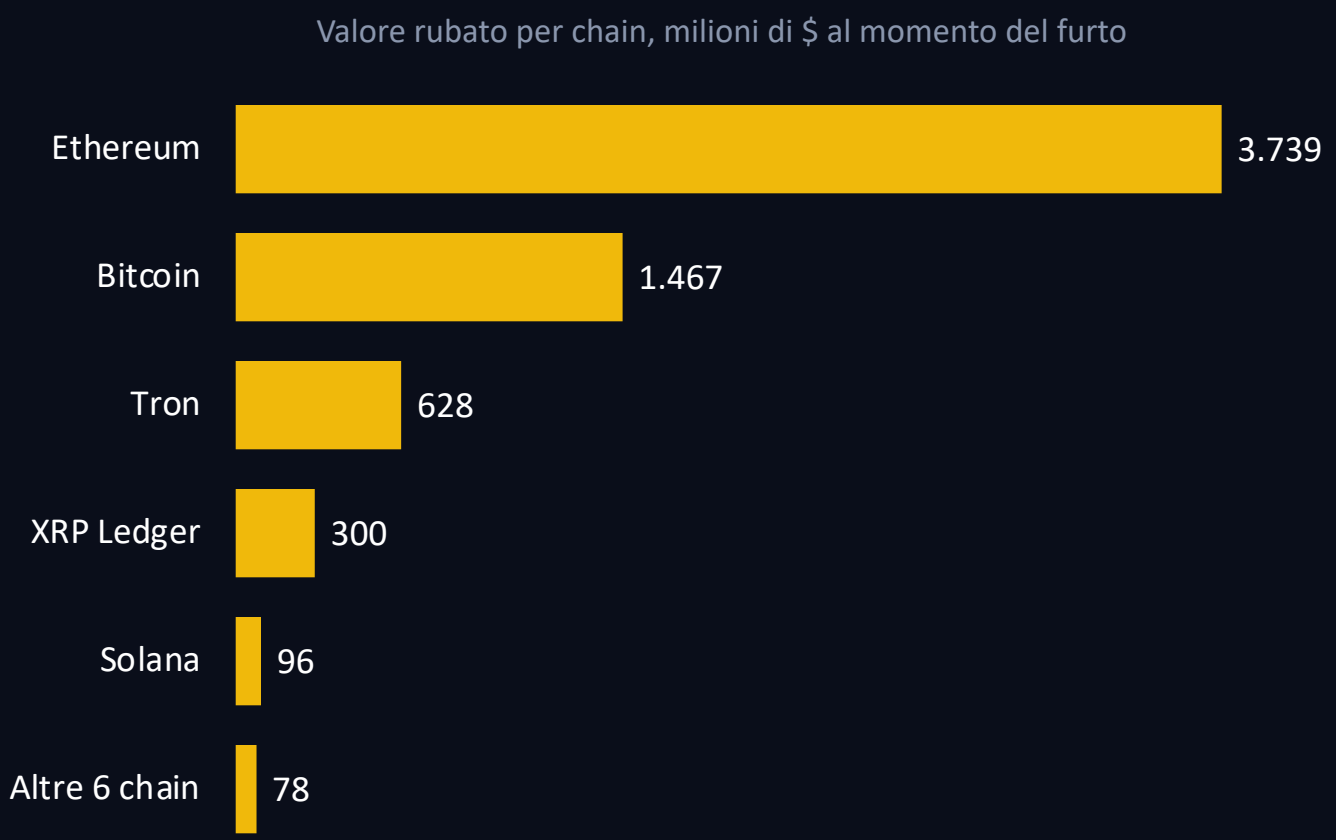
In breve
Come i numeri di un blocchetto di assegni: ogni firma vale per un numero preciso, e una volta sola.

A cosa serve
Impedisce di riusare una vecchia firma e fissa l'ordine delle transazioni.

Perché conta qui
Binance 14 consumava migliaia di numeri l'ora. Le autorizzazioni EIP-7702 valgono solo se il numero coincide esattamente: impossibile indovinarlo, da qui le 50 firme.

VERIFICATO ON-CHAIN

Dove ha colpito: i numeri per blockchain



≈ 6,3 mld $

Totale. Range tra le fonti: 5,9–6,43 mld

≈ 2,8 mld $

Congelati dagli emittenti (≈ 44%)

≈ 3,3 mld $

Non congelabili: ETH, BTC, XRP, SOL, TRX

Fonti: Arkham (per chain), Elliptic (totale e quota non congelabile a prezzi del 30/10). Altre 6: Arbitrum, Avalanche, Polygon, Optimism, Base, NEAR.

APPROFONDIMENTO

Blockchain, layer 2 e token: le reti colpite

Token: valori emessi sopra una blockchain

USDT · USDC · RLUSD · wBETH · ARB · OP · PEPE

Layer 2 e reti collegate a Ethereum

Arbitrum · Optimism · Base · Polygon

Blockchain indipendenti, ognuna con la sua moneta

Bitcoin · Ethereum · XRP Ledger · Solana · Tron · Avalanche · NEAR

In breve

Le blockchain sono strade diverse. Le layer 2 sono corsie veloci sopra l'autostrada Ethereum. I token sono le merci che viaggiano sulle strade.

Perché conta qui

Per ogni rete Binance tiene hot wallet separati, con chiavi e formati di firma diversi. Svuotarne dieci in mezz'ora richiede di controllare il sistema che firma per tutti.

VERIFICATO ON-CHAIN

36 ore di preparazione

28/10 07:39
Primo di tre prelievi da Tornado Cash (0,098 ETH): gas «pulito»

29/10 02:28
Deploy della prima versione dello sweeper

29/10 13:51
Prova 1: delega con 3 firme (nonce 0, 1, 2), una sola valida

29/10 15:59
Deploy dello sweeper finale 0x63e8…6fAe

29/10 16:25
Prova 2: sweep testato 3 volte su un wallet usa e getta

29/10 18:20
Rifornimento di gas: 1,08 ETH

29/10 20:05
Inizio dell'attacco

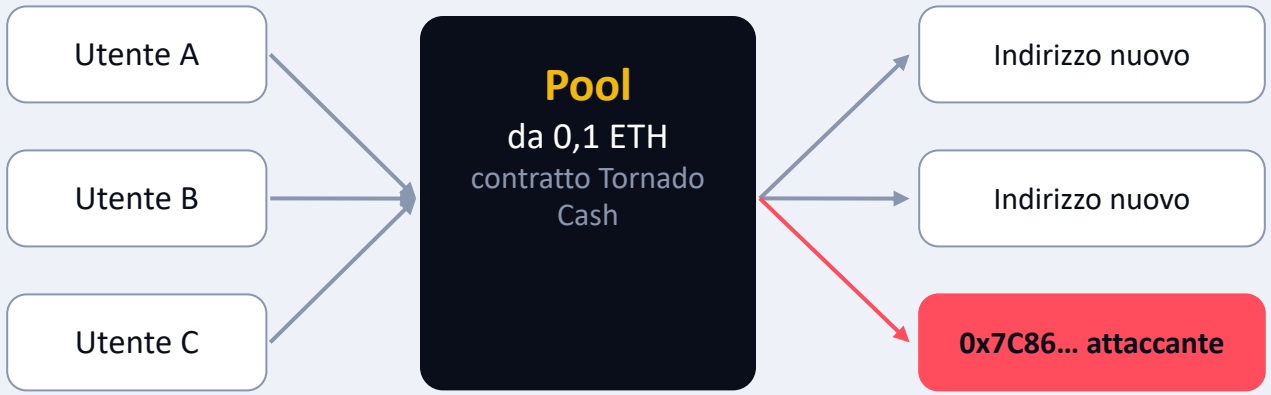
Il dettaglio che conta: la prova delle 13:51 usa lo stesso schema dell'attacco vero, più firme di cui una sola valida. L'attaccante sapeva già come aggirare il problema del nonce.

	FROM	TO	VALUE	TOKEN
2026-10-29 18:20:47	0xe4F9070e1316de2988f…	0x7C8601d4645b93cea45F7…	1.082	ETH
2026-10-29 08:23:11	Tornado.Cash : 0.1 …	0x7C8601d4645b93cea45F7…	0.098	ETH
2026-10-28 08:53:59	Tornado.Cash : 0.1 …	0x7C8601d4645b93cea45F7…	0.098	ETH
2026-10-28 07:39:47	Tornado.Cash : 0.1 …	0x7C8601d4645b93cea45F7…	0.098	ETH

Fonti: drk.vc (lettura diretta della chain), TRM Labs, Elliptic, Arkham (tabella: ingressi su 0x7C86, thread su X del 30/10). Orari UTC, scala non proporzionale.

APPROFONDIMENTO

Tornado Cash: da dove arriva il «gas pulito»



Chi ritira dimostra con una prova crittografica di aver depositato, senza dire quale deposito: il legame tra entrata e uscita sparisce.

Cos'è il gas

Ogni transazione su Ethereum paga una commissione in ETH. Anche un ladro deve pagarla.

Nell'attacco

Tre prelievi da circa 0,1 ETH: abbastanza per deployare lo sweeper e inviare le transazioni.

In breve

Una «lavatrice» per criptovalute: molti versano la stessa cifra, ognuno ritira su un indirizzo nuovo, e nessuno può dire quale moneta era di chi.

Come funziona

Contratti su Ethereum dal 2019, con pool di importo fisso. Il prelievo si dimostra con una prova a conoscenza zero, senza rivelare il deposito.

Stato legale

Sanzionato dagli USA nel 2022, sanzioni revocate a marzo 2025. Resta il mixer più usato sulle reti Ethereum.

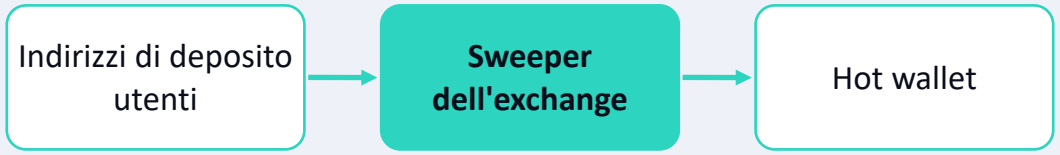
Fonti: TRM Labs (stato e quota di mercato), Decrypt (cronologia legale), Elliptic e drk.vc (prelievi dell'attaccante).

APPROFONDIMENTO

Cos'è uno sweeper

Uno sweeper è un programma, un bot o uno smart contract, che sposta automaticamente tutto il saldo di un indirizzo verso un altro.

Uso legittimo: raccolta dei depositi



Ogni utente ha un indirizzo di deposito personale. L'exchange raccoglie periodicamente quei fondi nei propri hot wallet.

Uso malevolo: lo svuotamento



Ogni fondo che arriva su un wallet compromesso viene girato subito al ladro, prima che il proprietario possa reagire.

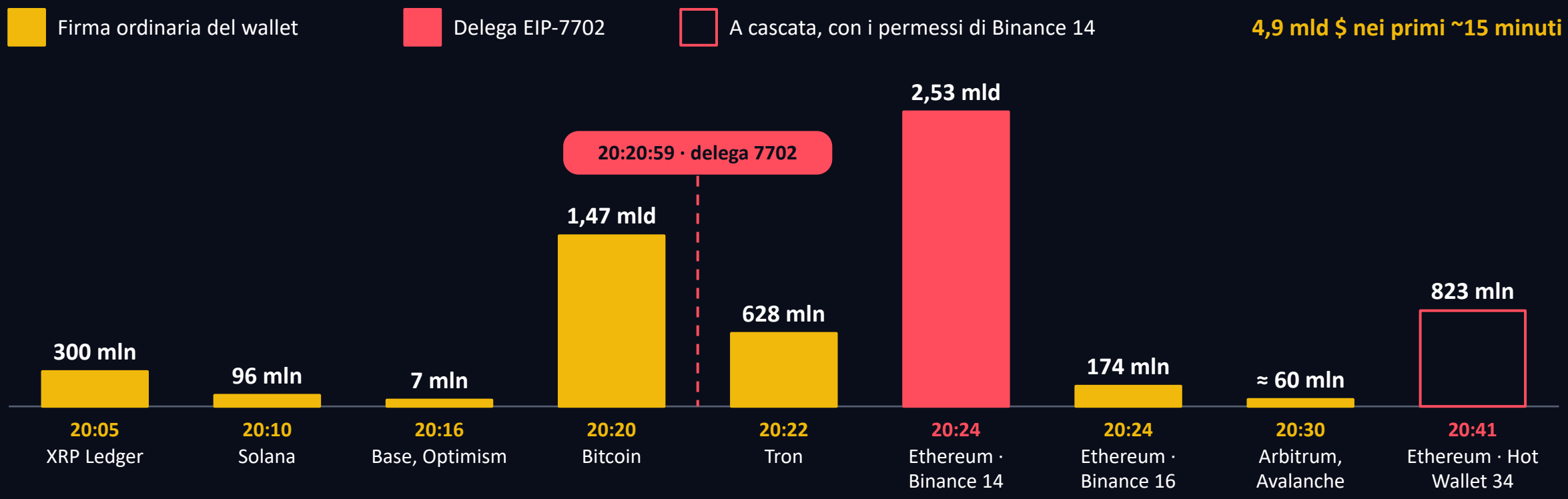
Il paradosso di Binance: i suoi sweeper legittimi rifornivano Binance 14, diventato lo sweeper malevolo dell'attaccante.

Fonti: drk.vc, Blockaid, jconorgrogan su X. Il contratto dell'attaccante è analizzato nel dettaglio più avanti.

VERIFICATO ON-CHAIN

Cosa è uscito dagli hot wallet, rete per rete

Ogni barra è un prelievo non autorizzato dagli hot wallet di Binance su una rete, in ordine di tempo. L'altezza è il valore in dollari, il colore dice come è stato fatto uscire.



Fonti: TRM Labs, Arkham, drk.vc, Elliptic. Orari UTC. Dopo le 20:41: altri sweep su Binance 14 fino alle 23:56 e una seconda ondata su Avalanche e Polygon alle 23:05.

VERIFICATO ON-CHAIN | IPOTESI DEGLI ANALISTI

Tre modi di svuotare i wallet, un solo punto debole

Firma ordinaria

Il wallet invia un normale trasferimento firmato. Per la blockchain è un prelievo di Binance come tanti.

Dove: XRP (5 wallet) · Solana · Base · Optimism · Bitcoin · Tron · Arbitrum · Avalanche (4 wallet) · Polygon · NEAR · Ethereum: Binance 16

≈ 2,8 mld $

Delega EIP-7702

Il wallet viene trasformato in uno sweeper che obbedisce solo all'attaccante, che lo svuota quando vuole.

Dove: Ethereum: Binance 14

2,53 mld $ più gli sweep successivi

A cascata

Uno smart wallet che prendeva ordini da Binance 14 viene svuotato usando proprio quei permessi.

Dove: Ethereum: Hot Wallet 34

823 mln $ in USDC

In comune: tutti e tre richiedono firme valide prodotte dai sistemi di Binance. I wallet non sono stati forzati uno per uno: secondo gli analisti è stato compromesso il sistema che firma per tutti.

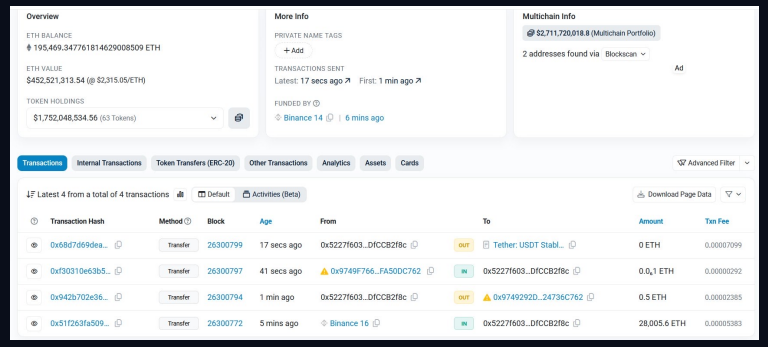
Fonti: drk.vc, Elliptic, TRM Labs, Arkham. Il numero esatto di wallet per rete non è pubblico per tutte le reti.

DALLA COMMUNITY SU X

La notte su X: il primo allarme

Spreek ✓
@spreekaway · **Segui**

Unconfirmed, but possibly massive binance hack. Entire Binance wallet drained into new EOA. Contract call was funded by Tornado Cash

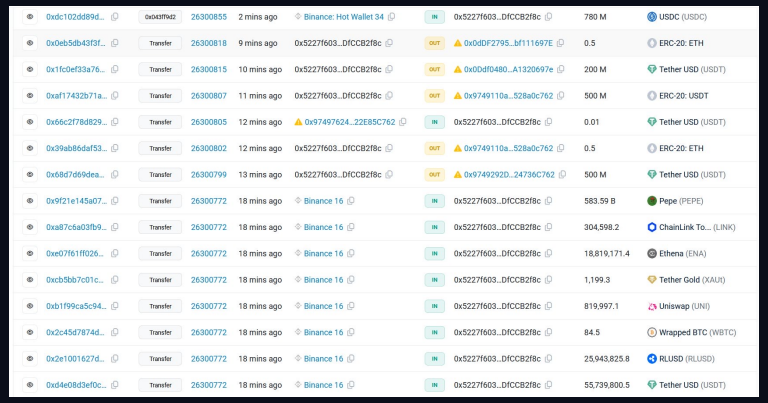


29/10 · 20:32 UTC
Primo allarme: un wallet di Binance svuotato verso un indirizzo nuovo, con la chiamata pagata da fondi Tornado Cash. Ancora da confermare.

Spreek ✓
@spreekaway · **Segui**

In risposta a @spreekaway

Also additional hot wallets going down. So far 14,16,34



29/10 · 20:43 UTC
Cadono altri hot wallet: Binance 14, 16 e 34.

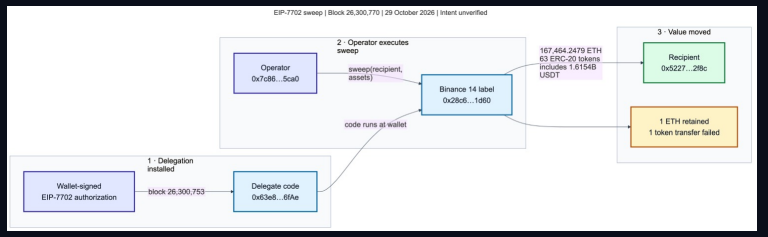
Odysseus | phylax.systems ✓
@odysseas_eth · **Segui**

1/4 EIP-7702 can turn the wallet itself into the sweeper.

A Binance-labeled wallet moved 167,464 ETH + 63 tokens, including 1.615B USDT, just 3m24s after a signed delegation was installed.

This is bad.

etherscan.io/tx/0x53bd38b81...



29/10 · 20:54 UTC
Con EIP-7702 il wallet stesso è diventato lo sweeper: 167.464 ETH e 63 token usciti 3 min 24 s dopo la delega.

Fonti: post su X degli account indicati, screenshot del 31/10/2026; clic sul post per aprirlo. Orari UTC.

DALLA COMMUNITY SU X

La notte su X: il meccanismo e i primi freeze

Blockaid
@blockaid_ · **Segui**

The attacker didn't know Binance 14's live nonce.

So they sprayed 50 EIP-7702 auths (18914775-18914824) in one type-4 tx.

Only 1 of 50 was a hit.

A 7702 auth is valid only for the current nonce at inclusion. The hot wallet was still firing. One nonce in that window landed.

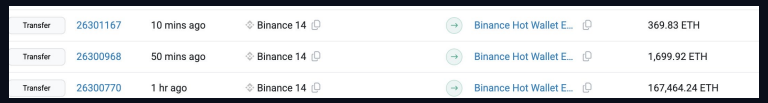


29/10 · 21:50 UTC
L'attaccante non conosceva il nonce: 50 autorizzazioni in una sola transazione, una a segno.

Conor
@jconorgrogan · **Segui**

The Binance hack is STILL GOING.

Binance evidently still has its deposit wallet sweeps turned on. This refreshes their hot wallet. The hacker is then sweeping the hot wallet



29/10 · 21:55 UTC
L'attacco è ancora in corso: gli sweep dei depositi di Binance ricaricano il wallet compromesso.

ZachXBT
@zachxbt · **Segui**

BREAKING: Arbitrum Security Council has executed a transaction to freeze ~$30.5M from the Binance Exploit.

Thanks to all other signers involved.

Exploiter address
0x3E2bf1ac6bf0934BBba6456C341c2EcbCED632d5

Trsanction hash: Mostra altro

12:14 AM · 30 ott 2026

30/10 · 00:14 UTC
Il Security Council di Arbitrum congela circa 30,5 mln $ legati all'exploit.

Fonti: post su X degli account indicati, screenshot del 31/10/2026; clic sul post per aprirlo. Orari UTC.

IN PAROLE SEMPLICI

La rapina in quattro atti

1

Preparazione

Soldi «puliti» da un mixer per pagare le spese, attrezzi costruiti su misura e provati due volte.

2

Accesso

Entrano nei sistemi interni di Binance, fino a quelli che autorizzano i movimenti di denaro.

3

Svuotamento

In circa 15 minuti svuotano casseforti su 10 blockchain diverse: 4,9 miliardi di dollari.

4

Fuga

Corsa a convertire i dollari digitali prima che vengano bloccati. Quasi la metà non ce la fa.

02

Come è stato possibile

Il punto d'ingresso, il sistema di firma e il deep dive su EIP-7702



DICHIARATO DA BINANCE | IPOTESI DEGLI ANALISTI | VERIFICATO ON-CHAIN

La catena d'attacco: cosa sappiamo e cosa no



Il precedente: Bybit, febbraio 2025
Anche lì si entrò dal computer di uno sviluppatore (di Safe{Wallet}) e furono manipolate le transazioni approvate dai firmatari.

Il contesto: «Contagious Interview»
Due giorni prima Binance dichiarava di aver bloccato attacchi con finti colloqui di lavoro che inducono i dipendenti a eseguire codice malevolo.

Fonti: Binance (30/10, 02:25 e 08:47 UTC), Elliptic, TRM Labs, Crypto Briefing (27/10).

IPOTESI DEGLI ANALISTI | DICHIARATO DA BINANCE

Non una chiave rubata, ma il sistema di firma

50 firme preparate in anticipo

Con la chiave in mano bastava firmare al momento giusto. Preparare 50 firme su un intervallo di nonce indica un accesso limitato o mediato da un sistema.

Binance 16 ha firmato da sé

24 secondi dopo lo sweep ha inviato 28.005 ETH all'attaccante, poi è tornato a servire i prelievi degli utenti.

Nove wallet, firme ordinarie

Su Bitcoin, Tron, XRP, Solana e le L2 i fondi sono usciti con transazioni normali, tutte in circa mezz'ora.

Binance

Nessuna prova di leak delle chiavi private. Non un'azione «one-click», né i soli permessi di un ingegnere.

Analisti

L'attaccante poteva far firmare ai sistemi di Binance transazioni scelte da lui (TRM, Blockaid, Elliptic).

Fonti: TRM Labs, drk.vc, Elliptic, Blockaid (via Cointelegraph), dichiarazioni di Binance e Richard Teng.

IN PAROLE SEMPLICI

Non hanno rubato la chiave: hanno preso l'ufficio timbri



Furto della chiave

Il ladro copia la chiave della cassaforte e la apre da solo.

Non è ciò che sembra successo.

Ufficio timbri

Il ladro entra nell'ufficio che approva i prelievi e si fa timbrare i suoi moduli.

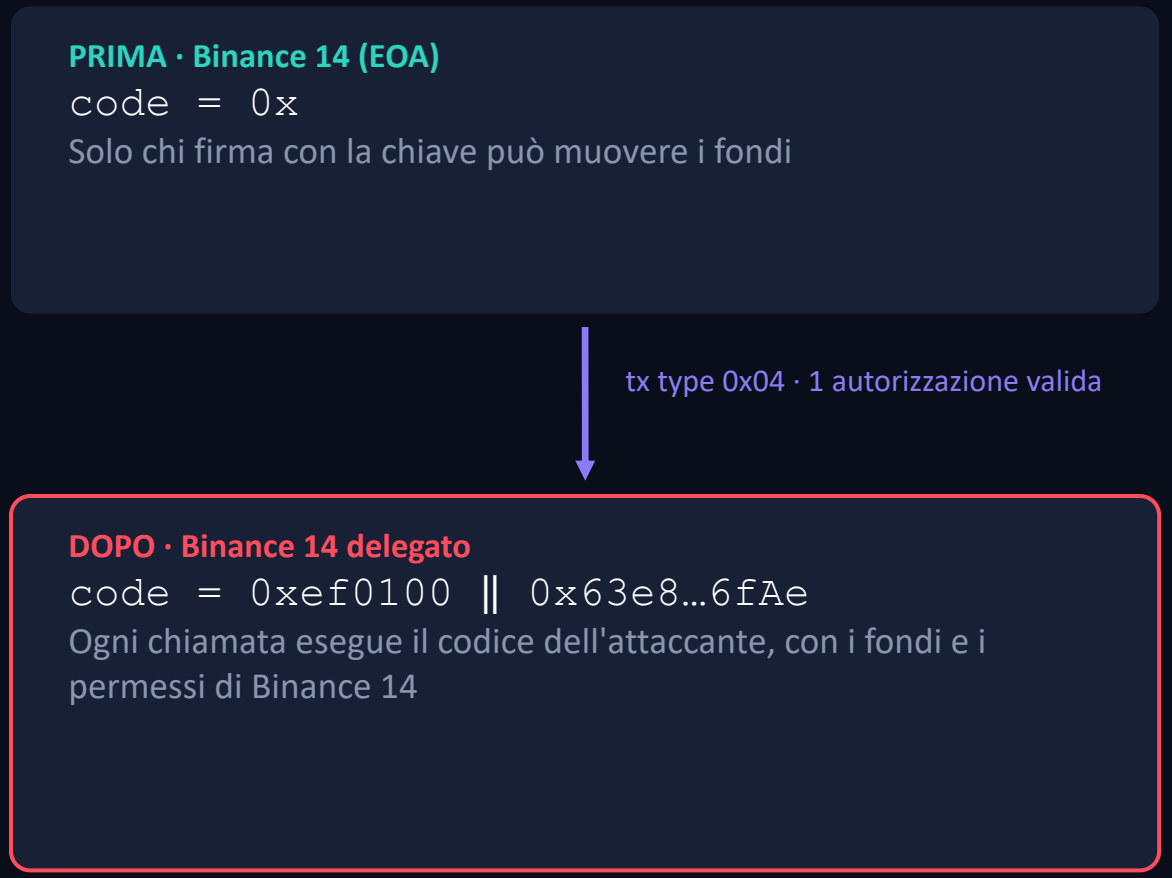
L'ipotesi più probabile.

Per la blockchain una firma valida è una firma valida: non sa se dietro c'è un dipendente o un intruso.

VERIFICATO ON-CHAIN

EIP-7702: un wallet che diventa programmabile

- Introdotta con l'upgrade Pectra di Ethereum, maggio 2025
- Nuova transazione di tipo 0x04 con una lista di autorizzazioni
- Ogni autorizzazione è firmata dal wallet su tre campi: chain_id, contratto delegato, nonce
- Effetto: il codice del wallet diventa 0xef0100 + indirizzo del contratto
- Resta attiva finché il wallet non firma una nuova delega; la revoca punta all'indirizzo zero
- Usi legittimi: transazioni in batch, gas sponsorizzato, permessi granulari



Fonti: specifica EIP-7702 (eips.ethereum.org), drk.vc, TRM Labs.

VERIFICATO ON-CHAIN

Le quattro regole di EIP-7702 sfruttate

1

Chi firma non deve essere chi invia

Nell'attacco: Bastavano le firme di Binance 14: transazione e gas li ha pagati l'attaccante.

2

Le autorizzazioni non valide vengono saltate

Nell'attacco: 49 firme su 50 sono state scartate in silenzio, senza far fallire la transazione.

3

La delega non si annulla se l'esecuzione fallisce

Nell'attacco: Anche un errore durante l'esecuzione non avrebbe rimosso la delega installata.

4

La delega è persistente

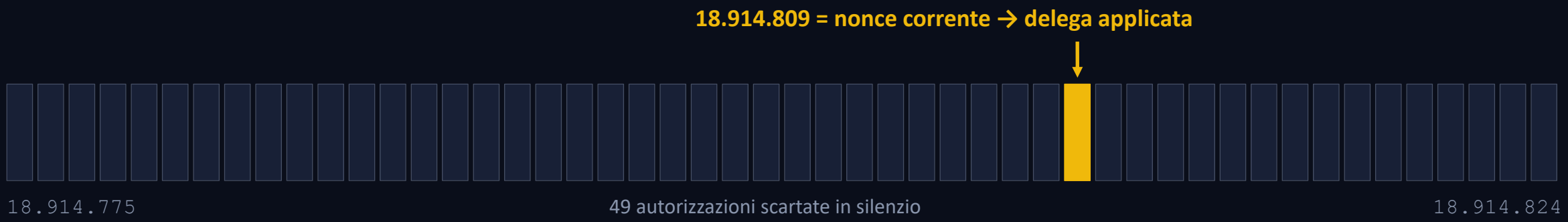
Nell'attacco: Lo sweeper è rimasto attivo per 3 ore e 46 minuti, svuotando ogni nuovo deposito.

Fonti: specifica EIP-7702 (eips.ethereum.org, eip7702.io), Hacken (revoca alle 00:10:35 UTC), drk.vc.

VERIFICATO ON-CHAIN

Il trucco dei 50 nonce

Un'autorizzazione vale solo se il suo nonce coincide con il contatore del wallet nel momento in cui la transazione entra in un blocco. Binance 14 inviava migliaia di transazioni l'ora: impossibile prevedere il numero giusto.



50

autorizzazioni in una sola transazione type-4, alle 20:20:59 UTC

1

applicata: Binance 14 ora esegue il codice dell'attaccante

3 min 24 s

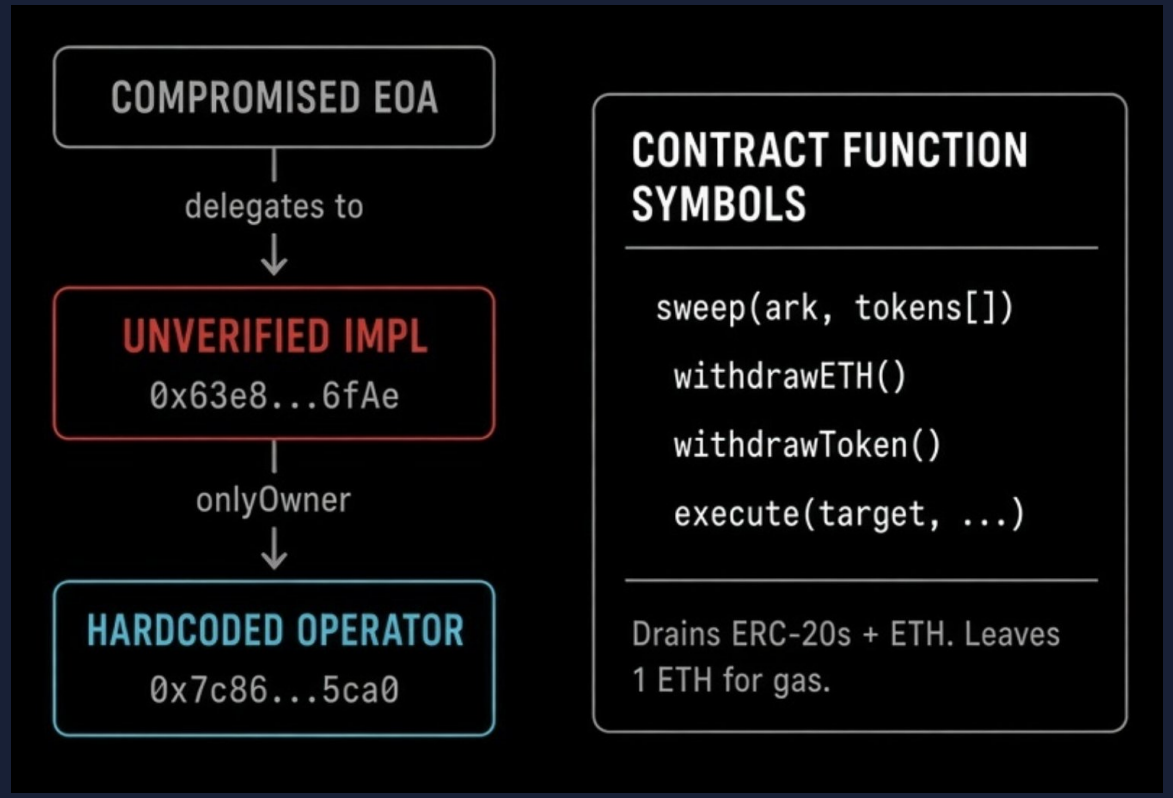
dopo, un solo sweep porta via 2,53 miliardi di $



Fonti: Etherscan (tx 0xad99264d…051298b, scheda Authorizations), Arkham (explorer della tx, thread su X del 30/10), Blockaid, drk.vc, Hacken.

IPOTESI DEGLI ANALISTI | VERIFICATO ON-CHAIN

Dentro lo sweeper: un attrezzo su misura



Un solo padrone
Accetta comandi solo dal wallet dell'attaccante: verificato con una chiamata di test.

Lascia 1 ETH
Le transazioni automatiche di Binance non fallivano per il gas e non scattavano allarmi.

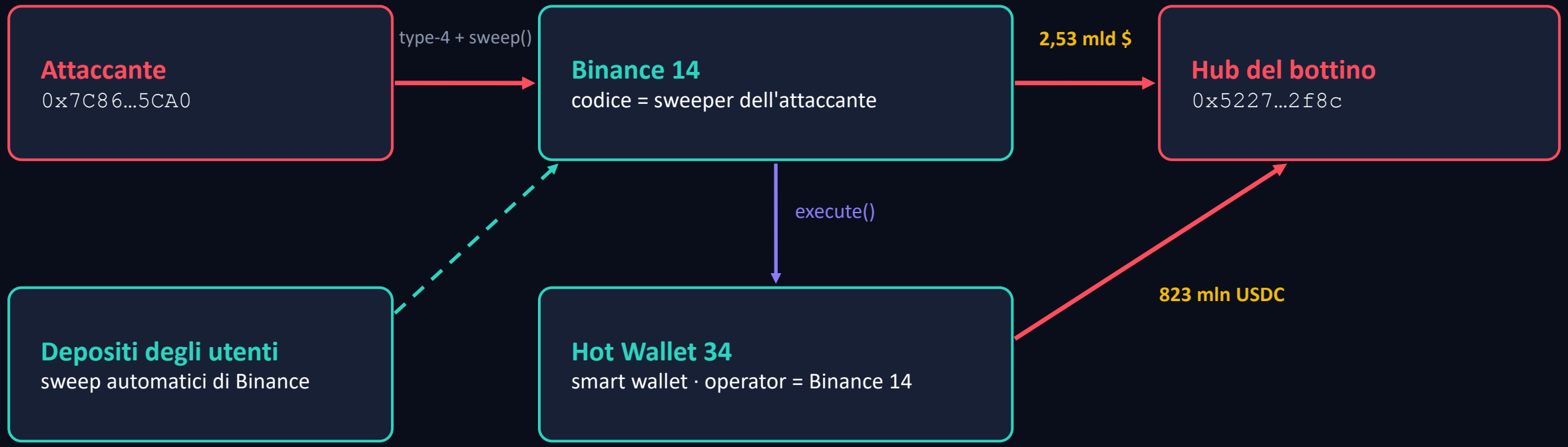
Non si ferma sui token bloccati
Se un token rifiuta il trasferimento passa al successivo: lo sweep è andato a segno.

Una porta laterale
Agisce come Binance 14 su altri contratti: così sono usciti 823 mln USDC.

Fonti: schema di Blockaid (post su X del 29/10, contratto non verificato su Etherscan), @XBToshi, account anonimo (bytecode ricostruito), odysseas_eth (Phylax), drk.vc.

VERIFICATO ON-CHAIN

L'effetto domino: da Binance 14 a Hot Wallet 34



Delegare un solo account significa consegnare anche tutti i permessi che quell'account ha su altri contratti.

Fonti: drk.vc, odysseas_eth (Phylax), TRM Labs. Tx USDC: 0xdc102dd8…e17481.

VERIFICATO ON-CHAIN

Il rubinetto aperto: 3 ore e 46 minuti

20:20:59	Delega installata su Binance 14
20:24:23	Sweep 1: 167.464 ETH e 63 token, 2,53 mld $
20:41 · 20:59	823 mln USDC prelevati da Hot Wallet 34
21:04	Sweep 2: 1.700 ETH e 4,4 mln $ in token appena arrivati
21:44	Sweep 3: 200 mln USDT spostati da Binance, finiti congelati
23:56	Ultimo sweep dei nuovi depositi
00:10:35	Binance 14 firma la revoca: delega azzerata

3 h 46 min

tra il primo sweep e la revoca della delega

Perché continuava a svuotarsi? Gli sweep automatici dei depositi degli utenti riempivano Binance 14, e ogni nuovo arrivo finiva all'attaccante. Le pause sono arrivate solo dopo le segnalazioni pubbliche.

Fonti: drk.vc, Hacken (revoca), Elliptic, jconorgrogan su X (sweep dei depositi).

IN PAROLE SEMPLICI

La procura con 50 numeri di protocollo

La procura

Il wallet firma: «da oggi le mie istruzioni le esegue questo maggiordomo». E il maggiordomo obbedisce solo al ladro.

Il protocollo

Una procura vale solo col numero di protocollo giusto, che cambia di continuo. Il ladro ne fa firmare 50 consecutive: una sarà buona.

Il rubinetto

La procura non scade. Ogni soldo che entra nella cassaforte esce subito verso il ladro, finché qualcuno non la revoca.

Senza procura il ladro avrebbe dovuto fare decine di prelievi uno alla volta, rischiando di essere fermato. Con la procura: un'unica mossa, in pochi secondi.

IPOTESI DEGLI ANALISTI

EIP-7702: causa o acceleratore?

Acceleratore decisivo

- Un solo sweep atomico di 64 token invece di decine di transazioni (Blockaid)
- Senza 7702 servivano oltre 70 transazioni con nonce in movimento: le difese avrebbero reagito (XBToshi)
- La delega ha aggirato i normali controlli di approvazione degli hot wallet (Teng, Binance)

Il problema è a monte

- Gli attaccanti potevano già autorizzare transazioni: la 7702 ha cambiato poco (Georgiev, Ambire)
- Nove wallet su altre chain sono stati svuotati senza 7702
- La 7702 non spiega come sono state ottenute le firme

Sintesi: la falla è nel sistema di firma. La 7702 ha trasformato quell'accesso in un'esfiltrazione unica, rapida e persistente.

Fonti: Cointelegraph (Blockaid, Ambire), Decrypt e Cointelegraph (Teng), XBToshi su X, drk.vc.

VERIFICATO ON-CHAIN

Le altre chain: prelievi firmati come sempre

Chain	Cosa è uscito	Ora (UTC)	Come è stato firmato
XRP Ledger	233,46 mln XRP da 5 wallet	20:05	Firma propria
Solana	≈ 970.500 SOL	20:10	Firma propria
Base · Optimism	4,74 mln VIRTUAL · 44,2 mln OP	20:16 · 20:18	Firma propria
Bitcoin	18.270,2 BTC in 11 transazioni	20:20	Firma propria, un solo blocco
Tron	612,7 mln USDT + 46,4 mln TRX	20:22	Firma propria
Arbitrum	74,6 mln ARB + ≈ 8.400 ETH	20:30	Firma propria
Avalanche	1,81 mln AVAX + 8,4 mln USDT	20:33	Firma propria, 4 wallet
Polygon · NEAR	Importi minori	dalle 23:05	Firma propria
Ethereum	**Binance 14 delegato · Binance 16 diretto**	**20:21**	**EIP-7702 + firma propria**

Fonti: drk.vc (lettura dei nodi), Elliptic (NEAR, Polygon), TRM Labs, Arkham, Blockaid (ETH su Arbitrum, stima).

03

Dopo il furto

Freeze, contromosse e dove sono i fondi oggi. Chi c'è dietro, in breve

VERIFICATO ON-CHAIN

Chi può congelare cosa

Congelabili

Token con un emittente che può bloccare un indirizzo

- USDT
- USDC
- RLUSD
- USD1
- XAUt
- PAXG
- wBETH

swap prima del blocco

Non congelabili

Asset nativi: nessuno può bloccarli on-chain

- ETH
- BTC
- XRP
- SOL
- TRX
- AVAX
- ARB
- OP

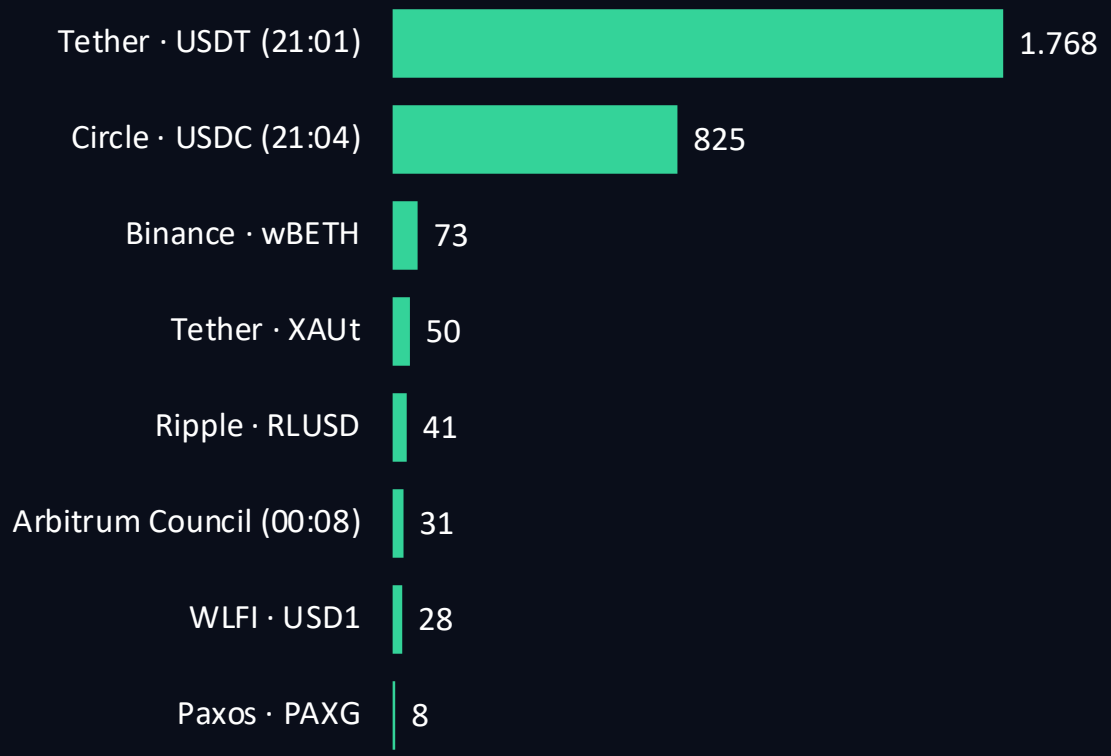
Eccezione: il Security Council di Arbitrum ha usato i poteri d'emergenza per spostare circa 30,5 mln $ fuori dalla portata dell'attaccante.

Fonti: Elliptic, TRM Labs, Arkham, ZachXBT (Arbitrum). Ripple può bloccare RLUSD ma non XRP.

VERIFICATO ON-CHAIN

La corsa dei freeze: 2,8 miliardi bloccati

Fondi congelati per emittente, milioni di $



Il portafoglio dell'attaccante su Arkham: in rosso le posizioni congelate

ASSET	CHAINS	PRICE		HOLDINGS	VALUE	
USDT TetherToken		$1	±0%	1.768B USDT	$1.77B	±0%
BTC Bitcoin		$78,005	-2.19%	18.27K BTC	$1.43B	-2.19%
ETH Ethereum		$2,231.74	-3.17%	497.897K ETH	$1.11B	-3.17%
USDC USD Coin		$1	±0%	824.597M USDC	$824.6M	±0%
TRX Tron		$0.35	+5.95%	682.71M TRX	$239.08M	+5.95%
SOL Solana		$97.01	-2.52%	970.549K SOL	$94.15M	-2.52%
WBETH Wrapped Binan...		$2,473.07	-3.17%	29.934K WBETH	$74.03M	-3.17%

37 min
tra lo sweep principale e il primo freeze di Tether

≈ 44%
del bottino è stato congelato

94%
dei fondi congelati sono stablecoin

Fonti: Arkham (importi; schermata dal thread su X del 30/10), TRM Labs (orari), Elliptic (quote). USDT include Ethereum, Tron e Avalanche.

VERIFICATO ON-CHAIN

Le contromosse dell'attaccante

Swap lampo

434 mln USDT → ≈ 160.000 ETH via Uniswap, 1inch e market maker, accettando perdite del 12–26% pur di battere i freeze.

Prestito su Aave

60 mln USDT come collaterale per prendere in prestito 19.762 ETH, prima che Aave congelasse i mercati.

Bitcoin a lotti

18.270 BTC divisi con una peel chain in 19 indirizzi, quasi tutti da 1.000 BTC. Finora mai mossi verso servizi.

Tron e bridge

234 mln USDT → 638 mln TRX su SunSwap; AVAX → USDC → bridge CCTP → ETH. Chainalysis vede pattern automatizzati mai visti.

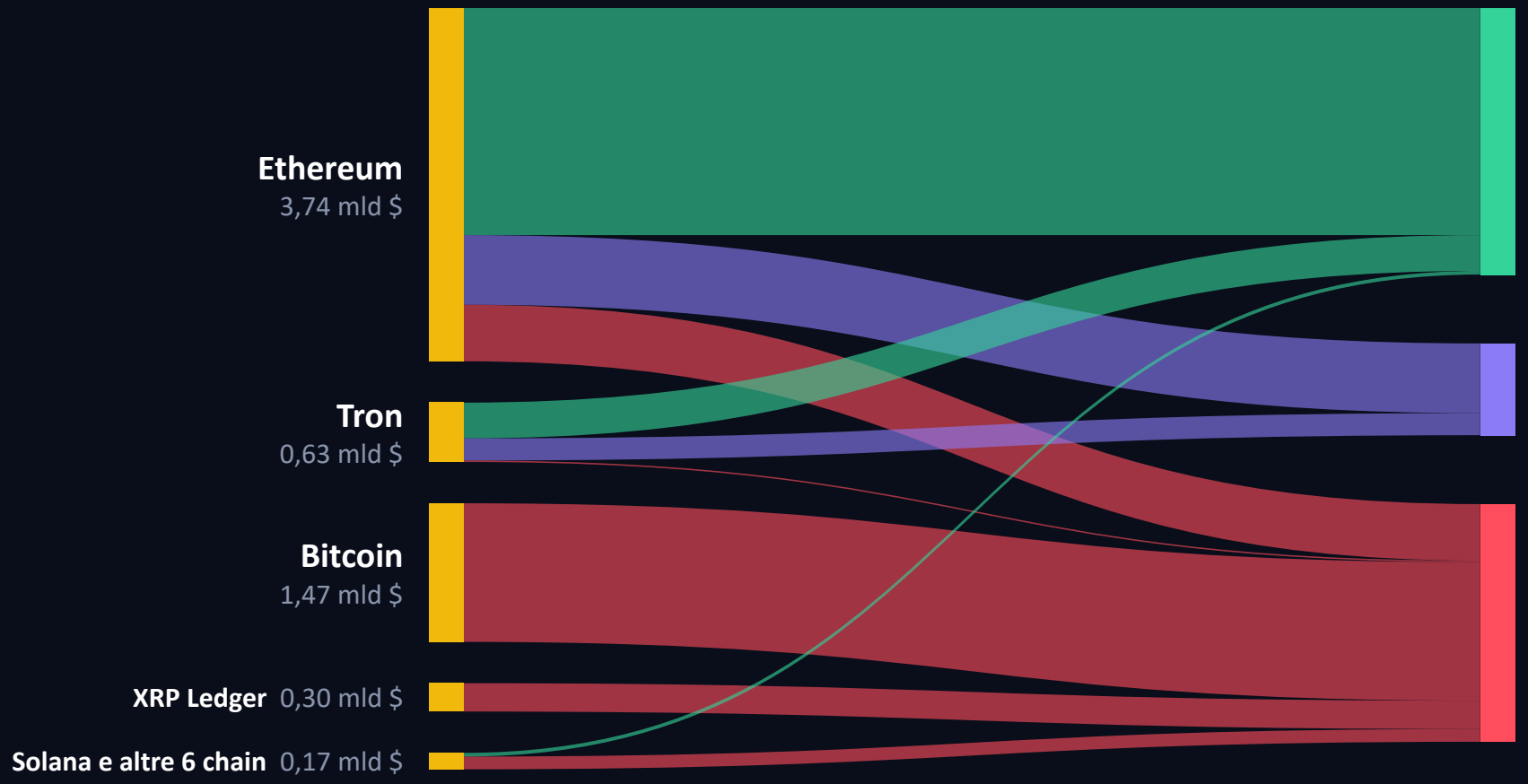
Fonti: Elliptic (swap, Aave, BTC, bridge CCTP), Arkham (sovrapprezzo 15–20%), Chainalysis (pattern di riciclaggio).

VERIFICATO ON-CHAIN

Dove sono finiti i 6,3 miliardi

RUBATO PER RETE

DESTINO DEI FONDI



Congelato dagli emittenti
2,82 mld $ · 45%
USDT, USDC, RLUSD, USD1, XAUt, wBETH e il freeze di Arbitrum

Convertito dall'attaccante
0,97 mld $ · 15%
Stablecoin e token scambiati in ETH e TRX, più 60 mln su Aave

Ancora nella forma rubata
2,52 mld $ · 40%
BTC, XRP, SOL, ETH e altri token che nessuno può bloccare

≈ 3,5 mld $ restano in mano all'attaccante

Elaborazione su dati Arkham, valori al momento del furto. A prezzi del 30/10 Elliptic stima ≈ 3,3 mld $ non congelabili.

VERIFICATO ON-CHAIN

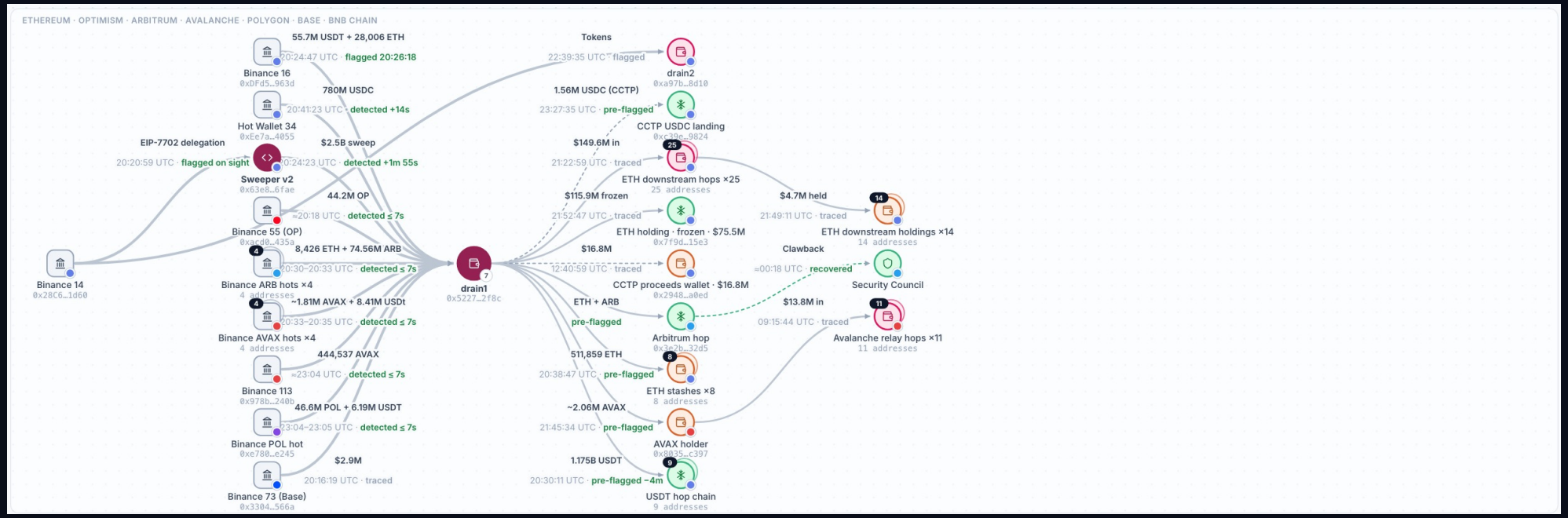
Dove sono i fondi oggi

≈ 6,3 mld $
presi in totale

≈ 2,7 mld $
congelati o recuperati

511.859 ETH
ancora all'attaccante

1.227
indirizzi su 12 blockchain



Fonti: Blockaid, tracker dei fondi (dati con l'avviso FBI del 31/10). Zarv: dei 608 indirizzi ETH pubblicati dall'FBI, 607 non hanno mai fatto una transazione.

IN PAROLE SEMPLICI

Perché un dollaro digitale si blocca e un ether no



Stablecoin = conto in banca

USDT o USDC sono emessi da un'azienda, che può congelare un indirizzo come una banca blocca un conto.



Ether e Bitcoin = contanti

Nessuno li emette e nessuno può bloccarli: chi li ha in tasca li può spendere.

Per questo, appena rubati, i dollari digitali vengono trasformati di corsa in ether: è una gara contro il tempo. Qui gli emittenti l'hanno vinta per 2,8 miliardi.

ATTRIBUITO DALL'FBI

Chi c'è dietro, in breve

TraderTraitor, Corea del Nord: lo conferma l'FBI

Attribuzione ufficiale del 31/10, con USSS e IRS-CI. Prima erano TRM e Chainalysis (alta confidenza) ed Elliptic (probabile).

Indizi

- Fondi mescolati con quelli dell'hack di Bitget dopo THORChain
- Modus operandi di Bybit: persone e sistemi di firma, non crittografia
- Scala: 11 chain coordinate in poche ore

Cautele di Elliptic, prima dell'FBI

- Sovrapposizione con Bitget ancora piccola: le reti di riciclaggio servono più clienti
- Conversione lenta degli stablecoin, insolita per la DPRK
- Per Bybit l'FBI attribuì in 5 giorni: qui in 2, il 31/10

Fonti: FBI Cyber Branch (31/10), TRM Labs, Chainalysis, Elliptic, ZachXBT.

04

Risposta e lezioni

Dove siamo oggi e cosa dovrebbe cambiare per exchange e custodian



DICHIARATO DA BINANCE

Come è cambiata la versione di Binance nelle prime 24 ore

	B Binance 30/10 · 02:25	B Binance 30/10 · 08:47	CZ CZ 30/10 · 09:33	YH Yi He 30/10 · 11:07	RT Richard Teng 30/10 · 14:34	B Update #2 30/10 · 19:58
Causa dichiarata	Laptop di un DevOps, poi un service container. Nessun leak delle chiavi	«Ulteriori punti di breach»: un attacco complesso			Delega 7702 oltre i controlli di approvazione; tracce auto-distrutte	Ancora nessun leak delle chiavi. Dettagli tecnici in ~48 ore
Danni e coperture			≈ 3 mld congelati, 1,x mld di SAFU: buco di ~2 mld, «gestibile»	Riacquisto via OTC delle altcoin rubate		6,34 mld accantonati, l'80% già negli stessi token
Prossimi passi	Prelievi sospesi, indagine in corso					Prelievi a fasi in ~34 ore; proof of reserves lunedì 2/11

VERIFICATO ON-CHAIN | DICHIARATO DA BINANCE

Dove siamo al 2 novembre: verificato o annunciato

Verificabile oggi

- Prelievi riaperti dall'1/11, a fasi
- ≈ 2,7–2,8 mld $ congelati o recuperati (Blockaid, Elliptic)
- All'attaccante restano ≈ 512.000 ETH (Blockaid)
- Proof of reserves del 31/10: BTC 100,04%, ETH e USDT 100%

Annunciato da Binance, da verificare

- Coperto il 90% delle perdite; prime 10 crypto al 100%
- Usati SAFU, fondo assicurativo dei futures e tesoreria
- SAFU da riportare a circa 1 mld $
- Nessuna prova di leak delle chiavi private

LE SCADENZE ANNUNCIATE · a che punto sono

31/10 · fatto
Snapshot della proof of reserves

1/11 · fatto
Prelievi riaperti a fasi

1/11 · in ritardo
Dettagli tecnici: non ancora

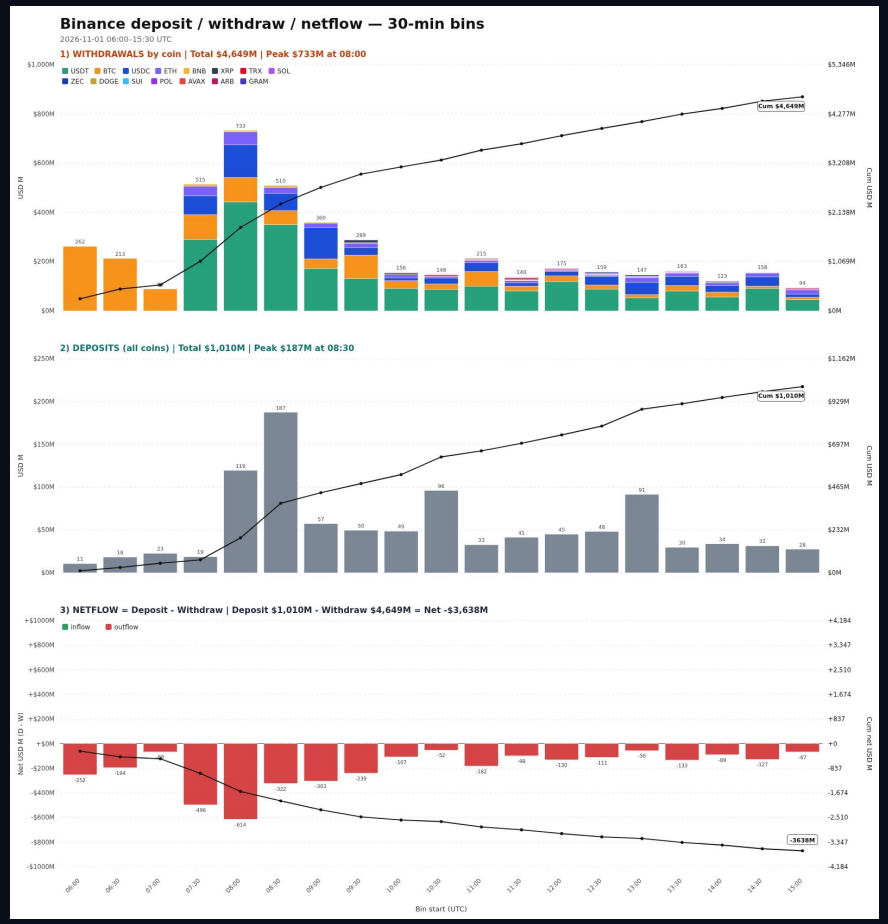
2/11 · atteso
Prova ZK della proof of reserves

Poi
Post-mortem completo

Stato al 2/11, mattina. Fonti: Binance (Update #3 e #4, post dell'1/11), proof of reserves, Blockaid, Elliptic, FBI.

DICHIARATO DA BINANCE

La riapertura: 4,6 miliardi usciti in 9 ore e mezza



4,65 mld $ — prelievi tra le 06:00 e le 15:30 UTC dell'1/11, picco di 733 mln alle 08:00

1,01 mld $ — depositi nello stesso periodo

-3,64 mld $ — flusso netto: il 2,1% dei 171 mld $ di asset dei clienti (proof of reserves del 28/10)

Dopo il picco iniziale i prelievi sono calati e si sono stabilizzati, secondo Binance: per ora niente corsa agli sportelli.

Fonte: Binance, post su X dell'1/11 alle 16:12 UTC (grafico e dati dichiarati). Il 2/11 sono ripartiti anche i prelievi in valuta, dollaro compreso.

RACCOMANDAZIONI

Sei lezioni per exchange e custodian

Monitora le deleghe

Un wallet di tesoreria con codice 0xef0100… è un allarme: controllo continuo di eth_getCode.

Revoca pronta

Un playbook testato e pre-approvato per firmare subito la revoca verso l'indirizzo zero.

Policy di firma

Rifiutare autorizzazioni 7702 inattese e chain_id 0. Un batch su un range di nonce è un indicatore di compromissione.

Segrega la firma

Infrastrutture e flussi di approvazione separati per chain e per livello di wallet.

Proteggi i developer

Postazioni, estensioni dell'IDE e finti colloqui di lavoro sono il nuovo perimetro.

Kill-switch per l'automazione

In un incidente si fermano anche gli sweep interni che alimentano il wallet colpito.

Fonti: TRM Labs e Hacken (EIP-7702 e infrastruttura di firma), Kaspersky (postazioni dei developer).

IN PAROLE SEMPLICI

Cinque cose da ricordare

1. La crittografia ha retto: hanno ceduto persone e processi.
2. Chi controlla chi firma controlla i fondi.
3. Le nuove funzioni di Ethereum velocizzano tutti, anche gli attaccanti.
4. Si può bloccare solo ciò che ha un emittente.
5. La risposta conta quanto la prevenzione: ogni minuto vale milioni.

Domande aperte

- Quali sono gli «ulteriori punti di breach»?
- Come sono state ottenute le firme valide: servizio di firma, policy engine, insider?
- Cosa ha distrutto il «meccanismo di auto-distruzione» citato da Teng?
- Quando arriveranno i dettagli tecnici promessi «entro 48 ore»?
- La prova ZK confermerà la proof of reserves del 31/10?
- Dove finiranno i ≈ 512.000 ETH ancora in mano all'attaccante?



Aggiornato al 2 novembre. Il deck verrà aggiornato dopo il post-mortem di Binance.

APPENDICE VERIFICATO ON-CHAIN

Indirizzi e transazioni chiave

Ruolo	Chain	Indirizzo o hash	Etichetta explorer · dettaglio
Wallet operativo dell'attaccante	Ethereum	0x7C8601d4645b93cea45F71e118A729332e6B5CA0	Binance Hot Wallet Exploiter
Contratto sweeper	Ethereum	0x63e842B054Bd624a465454D533C33F573e9c6fAe	Binance Hot Wallet Exploiter 24
Hub del bottino	Ethereum	0x5227f603C1eE34CE3C06eFe6477003BDfCCB2f8c	Binance Hot Wallet Exploiter 2
Hot wallet delegato	Ethereum	0x28C6c06298d514Db089934071355E5743bf21d60	Binance 14
Hot wallet, firma propria	Ethereum	0xDFd5293D8e347dFe59E90eFd55b2956a1343963d	Binance 16
Smart wallet svuotato a cascata	Ethereum	0xEe7aE85f2Fe2239E27D9c1E23fFFe168D63b4055	Binance: Hot Wallet 34
Tx type-4: 50 autorizzazioni, 1 valida	Ethereum	0xad99264d5532ae0dd04b2004eebda05f25657e70dacb764f7ac8d4ccd051298b	Blocco 26.300.753 · 20:20:59
Sweep: 167.464 ETH + 63 token	Ethereum	0x53bd38b816c23e74134786c29a8c18d792777998a3b9326047b583100e88e2f3	Blocco 26.300.770 · 20:24:23
780 mln USDC da Hot Wallet 34	Ethereum	0xdc102dd89dded5a83f1008906883ffb7c81ff3b7d7965d8c7277d170b5e17481	20:41:23 UTC
Indirizzo dell'attaccante	Arbitrum	0x3E2bf1ac6bf0934BBba6456C341c2EcbCED632d5	Binance Hot Wallet Exploiter 9
Ricezione dei 18.270,2 BTC	Bitcoin	bc1q0mtc2f5agpkvlq6hhahmfr3hlr55kyfjhl2mnm	Ricevuti 18.270,2 BTC, già ridistribuiti
Ricezione dei 612,7 mln USDT	Tron	TG5iBMQPrDzJJAUM8GMVBf1hRaJ1wvzsGi	≈ 312 mln USDT ancora presenti

APPENDICE

Glossario

EOA	Wallet controllato da una chiave privata, senza codice.
Nonce	Contatore delle transazioni di un wallet; ogni firma vale per un numero preciso.
Sweeper	Contratto che trasferisce in blocco tutti i fondi di un wallet verso un indirizzo.
Freeze / blacklist	Blocco di un indirizzo da parte dell'emittente di un token.
Bridge	Servizio che sposta valore da una blockchain a un'altra.
Mixer	Servizio che mescola i fondi di molti utenti per nasconderne l'origine (es. Tornado Cash).
Hot wallet	Wallet online usato per i prelievi quotidiani.
EIP-7702	Standard Ethereum che permette a un EOA di delegare il proprio comportamento a un contratto.
Stablecoin	Token ancorato al dollaro, emesso da un'azienda che può bloccarlo.
Peel chain	Catena di trasferimenti che suddivide i fondi in tanti indirizzi.
SAFU	Fondo di emergenza di Binance per coprire le perdite degli utenti.
Gas	Commissione in ETH pagata per ogni transazione su Ethereum.

APPENDICE

Fonti

Livello 1 · riferimento

- TRM Labs, report sul blog
- Elliptic, report e blocklist
- Chainalysis, blog e X
- Arkham, thread ed entità
- Binance, comunicati ufficiali
- Specifica EIP-7702
- FBI Cyber Branch, attribuzione

Livello 2 · analisi tecnica

- Blockaid (X, Cointelegraph)
- drk.vc, analisi on-chain
- Hacken, analisi
- odysseas_eth (Phylax)
- Protos, Cointelegraph, Decrypt
- Blockaid, tracker dei fondi

Livello 3 · segnali

- Spreek, primo alert
- ZachXBT, freeze e collegamenti
- PeckShield, movimenti
- jconorgrogan, sweep dei depositi
- XBToshi (anonimo), bytecode
- Kaspersky, sicurezza endpoint
- Zarv (zarvxbt), diagrammi dei flussi